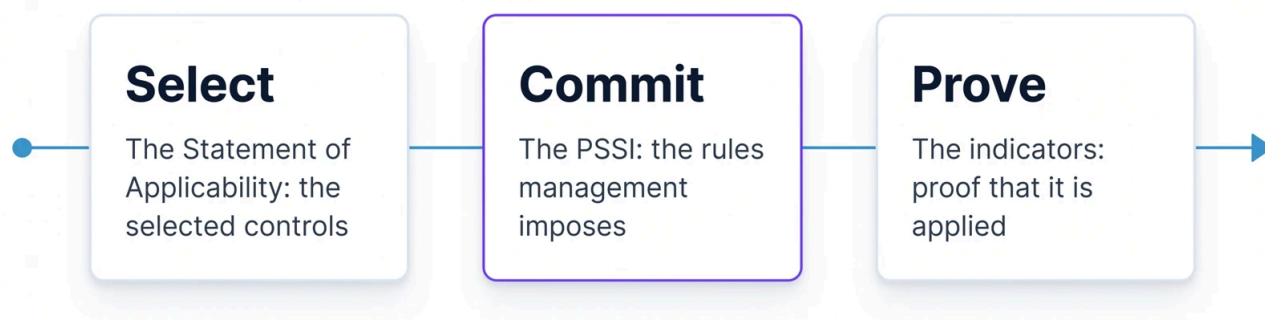


Information Security Policy and ISMS Documentation Architecture

In session 8, the group selected its controls in the Statement of Applicability. Each control has a justification. But a table of controls binds no one. An administrator is not bound by a CISO's working document. A provider cannot be blamed for a rule it never received.

One floor is missing between the selected control and the applied control: the written rule, validated by someone with the power to impose it, and distributed to those it concerns. That floor is the PSSI, the French term for the information security policy. This lecture explains what it is, how it is written, how it breaks down into more precise documents, and how one checks that it is applied.

✓ From selecting controls to the rule that binds



Session objectives

By the end of this lecture:

- Explain what a PSSI is, what it commits, who validates it and who must know it.
- Describe the four-phase process for developing a PSSI, with the deliverable of each phase.
- Build the documentation architecture of an ISMS: framework policy, topic-specific policies, procedures, records.
- Place the regulatory requirements bearing on the PSSI, and check what the group already covers.
- Wire up a steering indicator, distinguish a correction from a corrective action, and spot a finding nobody watches.

Prerequisites

- The Statement of Applicability and the ISMS scope from session 8, deliverable D8. The PSSI makes them enforceable.
- The treatment plan and the register from session 7, deliverable D7, and the findings of the session 4 audit report. The rules written today come from there.
- The PSSI as a notion, set in session 1: the group has a governance framework, codified directives and a RACI matrix. Today, the document gets written.

This session is the last substantive session before the defences. Its question is simple: how an organization turns analyses into daily obligations, then checks, quarter after quarter, that those obligations are kept.

✓ The PSSI: the document by which top management commits

As a reminder, the official vocabulary of the ISO/IEC 27000 family defines a policy as the intentions and direction of an organization, as formally expressed by its top management. Every word weighs. They are the intentions of the organization, not the CISO's. Top management expresses them, not the technical team. And the expression is formal: written, validated, dated, enforceable.

What a PSSI is. It is the policy applied to information systems security. In France, the reference is the guide for developing a PSSI, published in 2004 by the DCSSI, the central directorate for information systems security, replaced by the ANSSI in 2009. The guide says three things:

- What the PSSI represents: « La PSSI traduit la reconnaissance formelle de l'importance accordée par la direction générale de l'organisme à la sécurité de son ou ses systèmes d'information. » (The PSSI expresses the formal recognition of the importance executive management attaches to the security of its information systems.)

- Its status: it « doit être prise en compte et validée au niveau de responsabilité le plus élevé comme un instrument de gestion des risques SSI » (must be taken into account and validated at the highest level of responsibility as an information security risk management instrument).
- Its distribution: « La PSSI est un document général diffusable » (the PSSI is a general document that can be distributed). It is known to all internal actors and, where needed, to the subcontractors and providers who access the information system.

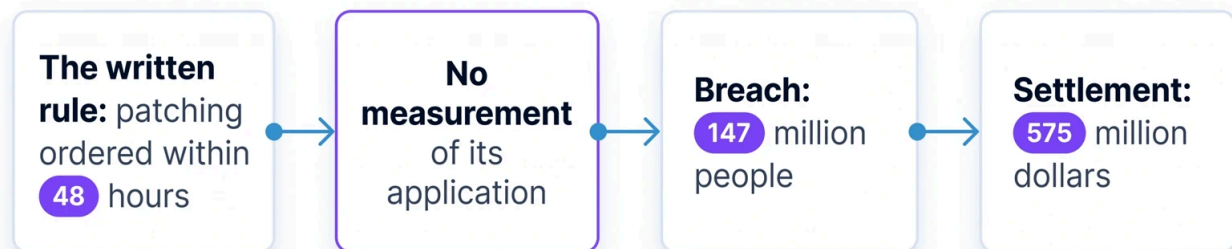
The standard outline. The guide organizes the PSSI in five questions. The table shows that the group already has the answer to each.

The standard-outline question (DCSSI guide, 2004)	What answers it in the MERIDIAN file
Why protect and build trust: stakes, regulatory aspects, threats	The scoping from session 1, the regulatory qualification from session 3, the risk sources from session 5
What to protect: assets to protect and scale of needs	The session 2 mapping: business assets, supporting assets, DICT needs, Top 5
Who protects: organization, responsibilities and information security management	The governance and RACI matrix from session 1
How to protect: a coherent, operational set of security rules	The controls selected by the session 8 Statement of Applicability, translated into rules: today's work
When to protect: consideration of the entire life cycle	Integrating security into projects, session 6

The substance of the PSSI therefore already exists. What remains is writing and validation.

The limit. A validated PSSI protects nothing by itself. It is a text. The Equifax case shows it. In 2017, this American credit agency suffered a breach affecting 147 million people. The cause, according to the American regulator: a known vulnerability, never patched. The company did have a written rule: patch vulnerable systems within 48 hours. Nobody checked that it was applied. The case ended in 2019 with a settlement of at least 575 million dollars.

💡 Key points. A policy is an act of top management, written and enforceable. The PSSI is that act for information systems security. Its substance already exists in the file. A rule with no measurement of its application does not protect: that is why the PSSI calls for indicators.



Developing the PSSI: four phases, four deliverables

The 2004 guide gives the method: « La démarche d'élaboration de PSSI se déroule en 4 phases successives » (the PSSI development process unfolds in four successive phases). The table gives the phases, their tasks and their deliverable.

Phase	Main tasks	Deliverable
Phase 0: preliminaries	Project organization, building the reference base	Scoping note
Phase 1: developing the strategic elements	Scope, stakes and orientations, legal and regulatory aspects, scale of needs, expression of security needs, threat origins	Strategy note
Phase 2: selecting the principles and drafting the rules	Choice of security principles, drafting of the rules, summary notes	Summaries of rules and impacts
Phase 3: finalization	Finalization and validation of the PSSI, development and validation of the action plan	PSSI and action plan

Two deliverables carry familiar names: the scoping document and the strategy note. They are the documents the group has produced since session 1. The module does not follow the guide to the letter, but it follows its logic: a policy is built from the scoping toward the rules, through the strategy, and is validated at every step. The strategy note, finalized today, is the strategic floor. The PSSI is its translation into rules.

Where the module does phases 2 and 3. The selection of principles is done: it is the session 8 Statement of Applicability. The drafting of rules starts this morning, at the workshop, with one section of the framework PSSI, without going as far as the complete document. The finalization and validation of the PSSI are not played out in the module: it stops at the section drafted and validated in the tool by another group member, and the session 10 viva stands in for the presentation at decision level. The phase 3 action plan already exists, it is the session 7 treatment plan; it is not rewritten.

On the rules themselves, the guide brings two things:

- A catalog of security principles, in 16 domains, split into organizational, implementation and technical principles. Each principle « pourra être décliné en règles d'application pour rédiger une PSSI » (may be broken down into implementing rules to draft a PSSI).
- A warning: do not copy the principles without analysis. A catalog is a starting point. A PSSI that copies a reference framework without confronting it with real risks produces paper, not security.

A note on dates. This guide dates from 2004. It knows neither ISO/IEC 27001, nor EBIOS Risk Manager, nor NIS 2. Its method and its standard outline remain the reference for the document. Its link with the texts of 2026 comes later in this lecture.

💡 Key points. Four phases: preliminaries, strategic elements, rules, finalization. Two of their deliverables are already written, the scoping document and the strategy note. Rules derive from the risk analysis, they are not copied from a catalog.

✓ The documentation architecture: distributing authority and speed

The problem. An organization does not fit in a single document. If the PSSI held at once management's commitment, the password policy, the operating procedure for account reviews and the exception form, it would run two hundred pages. Nobody would read it. It would have to be revalidated by the Executive Committee at every version change of a tool.

The solution. Documents are organized in floors. Each floor has its own level of validation, its own audience and its own review rhythm. Each document refers to the floor above, which grounds it. Its official basis:

- The 2004 guide: the other policies are « des déclinaisons de la PSSI dans un environnement métier ou technique particulier » (breakdowns of the PSSI in a particular business or technical environment), and the

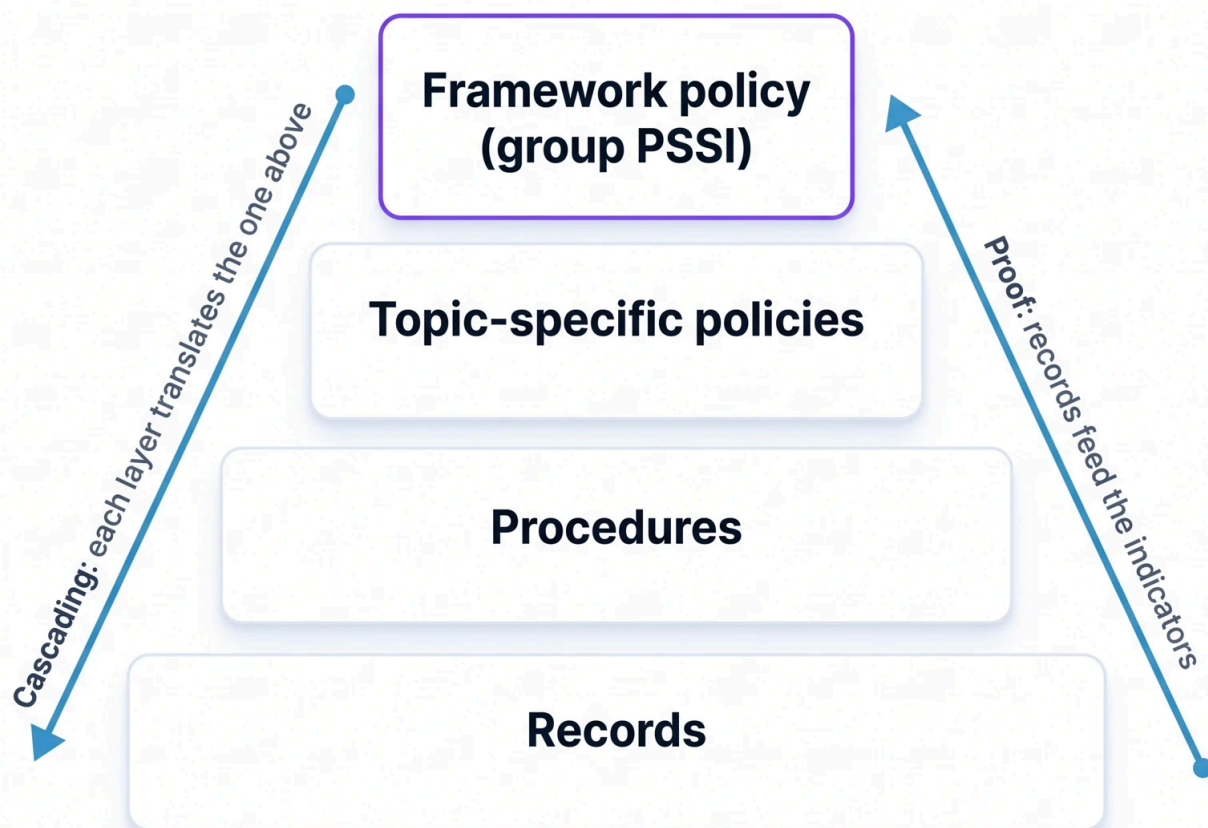
PSSI rules receive « une déclinaison opérationnelle, notamment sous la forme de procédures » (an operational breakdown, notably as procedures).

Floor	What it contains	MERIDIAN example	Who validates it	Who reads it	Rhythm of change
Framework policy (group PSSI)	Executive management's commitment, stakes, organization, framework rules	The framework PSSI and its codified directives, such as the quarterly review of privileged accounts	The Executive Committee, on a draft by the Group CISO	Everyone, service providers included	Slow: annual review, or major change
Topic-specific policies	Rules for a domain or a subsidiary: access control, encryption, acceptable use	The Santé adaptation of the encryption-at-rest directive	Group CISO or subsidiary management, according to the RACI	The teams of the domain concerned	Medium: at the rhythm of risks and audits
Procedures	The how, step by step: roles, stages, evidence produced	The procedure for the quarterly review of privileges on the business databases	The process owner	Those who execute	Fast: at every change of tool or organization
Records	The proof that it is done: minutes, statements, logs	The signed record of an account review, an audit export from the GRC tool	Nobody validates them: they are produced	The auditor, the PSSI, executive management through the indicators	Continuous: every execution creates some

A document that cannot cite the rule it derives from is an orphan document. And the records at the bottom feed the indicators that tell management whether its policy is applied: that is the loop that was missing at Equifax.

The limit. The pyramid describes documents, not their quality. Four floors of vague texts make a bureaucracy, not an ISMS. This afternoon's writing workshop deals with that risk.

💡 Key points. Four floors: framework policy, topic-specific policies, procedures, records. The lower the floor, the more precise the document, the faster it changes and the lower it is validated. Each document cites the floor that grounds it; each record proves that a rule is applied.



✓ What incoming law requires of the PSSI

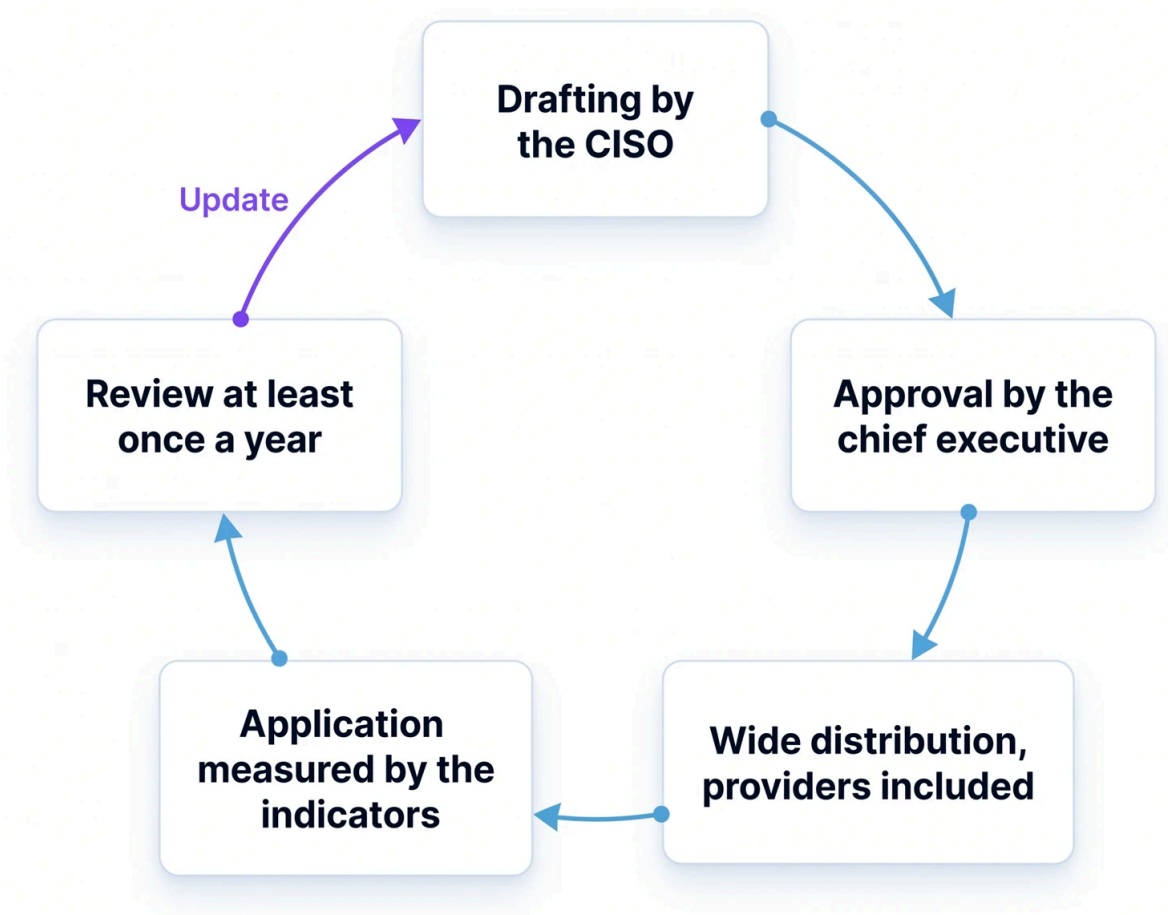
The PSSI was a matter of good governance. It is becoming an obligation. For the group's subsidiaries that will fall within the scope of NIS 2, the European directive on the security of network and information systems, the reference text is the French framework seen in session 3. It is still a working version: its objectives will become mandatory when a decree sets them. Its objective on the governance framework turns doctrine into requirements.

What the reference framework requires	Where the MERIDIAN group stands
« L'entité définit et met en œuvre une politique de sécurité des systèmes d'information (PSSI). » (The entity defines and implements an information systems security policy, the PSSI.)	In progress: it is today's work
A minimum content: the organization of governance with internal and external roles, strategic orientations derived from the overall strategy, the commitment of the chief executive	The session 1 RACI, the strategy note, the commitment to be validated by the Executive Committee
« Le dirigeant exécutif de l'entité approuve la PSSI. » (The entity's chief executive approves the PSSI.)	To be added to the validation circuit: drafting by the PSSI is not enough
« La PSSI est au minimum revue annuellement » (the PSSI is reviewed at least annually), and updated in the event of a major change in the threat or the context	To be written into the PSSI itself: it is a rule about the rule
The PSSI is derived « en politiques de sécurité relatives à des thèmes précis » (into topic-specific security policies), with an imposed minimum: encryption, physical and logical access control, review of the application of measures, account management	Floor 2 of the pyramid; the group already has codified directives on three of these four themes

Two remarks on this table.

The annual review is not new. The first principle of the 2004 guide already provided for a re-examination of the PSSI at every major change in the context, the information system, the threat or the needs. A policy that does not provide for its own revision dies.

Responsibility goes up to the chief executive. The framework names them responsible for digital security and for compliance monitoring. Management's commitment becomes a documented obligation, and the PSSI is the document where it is written.



💡 Key points. For entities within the scope of NIS 2, the PSSI becomes a requirement: defined, approved by the chief executive, reviewed every year, broken down into topic policies. The group already covers three of the four minimum topics through its directives.

✓ Keeping it alive: the four follow-ups

The 2004 guide describes what follows the validation of a PSSI. Four axes:

- the operational breakdown of the rules, notably into procedures;
- an entity to monitor and steer the action plan;
- the audit of the PSSI, « notamment construit autour de contrôles réguliers à plusieurs niveaux de l'application opérationnelle ou à l'aide de tableaux de bord SSI » (notably built around regular checks at several levels of operational application or using information security dashboards);
- an alert and watch organization, to maintain the security level over time.

In three verbs: the Statement of Applicability selects the controls, the PSSI commits management to rules, the indicators prove that the rules are applied. Select, commit, prove.

✓ Steering: an indicator's circuit, nonconformity and corrective action

Three notions, then two short examples on the quarter's readings given at the CISO's desk. The afternoon's deliverable D9 uses the second.

The steering indicator

The strategic indicator, seen at the CISO's desk, informs a management decision. The steering indicator drives an action. It is read more often and watched by those who act. Above all, it is wired: when it crosses its threshold, something planned happens, an analysis, an escalation, an action.

The same figure can serve both, PSSI coverage for example. What changes is the circuit around the figure. An indicator without a circuit is a mood indicator: everyone looks at it, nobody answers for it. The question to ask of any indicator: what happens when it crosses its threshold, and who answers for it?

Continual improvement

The problem it addresses is wear. Controls age, threats change, organizations move. A frozen system degrades silently.

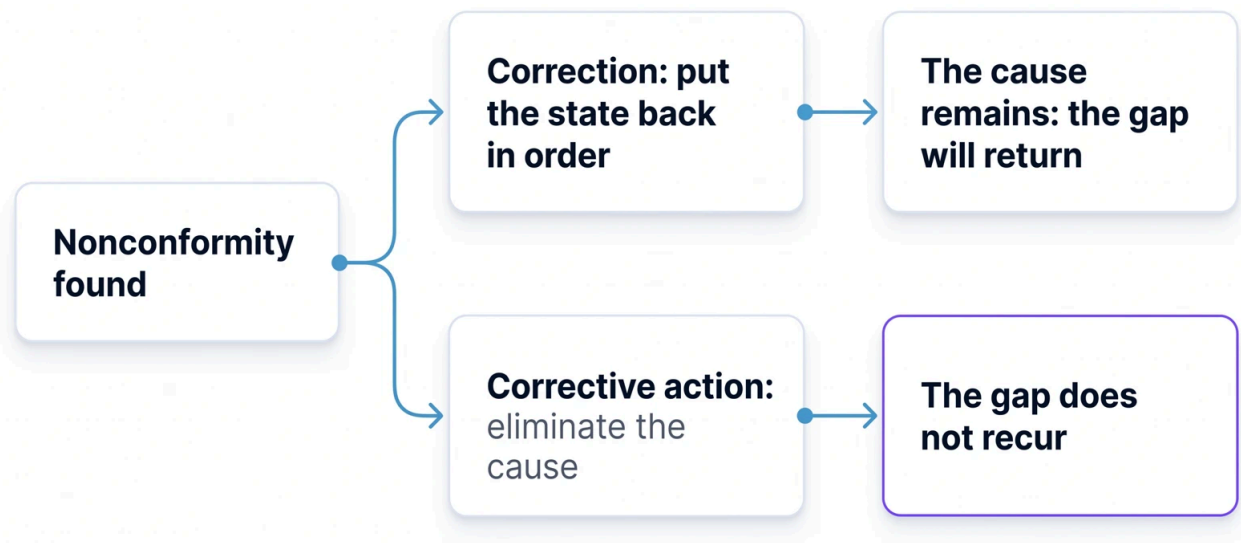
The official vocabulary defines it as "recurring activity to enhance performance". The important word is recurring: it is not a project launched after an incident, it is a permanent operating mode.

Two moves, which the vocabulary distinguishes:

- a nonconformity is the non-fulfilment of a requirement;
- a corrective action eliminates the cause of a nonconformity and prevents its recurrence.

Not to be confused with correction. Correcting means restoring order: catching up on the backlog, repairing the server. Corrective action treats the cause. Both are useful, only the second improves the system.

The limit is human: a loop that looks for culprits rather than causes stops within a quarter, because nobody reports anything anymore.



The PDCA cycle

PDCA means plan, do, check, act: the historical model of continual improvement, inherited from quality approaches, which structures every turn of the loop, an action planned with an expected result, carried out, checked, then generalized or reworked.

One trap to know: PDCA is not the structure of the ISO/IEC 27001:2022 standard. It was, in an older edition. Saying today that the standard is a PDCA is a classic interview mistake. The model remains useful for reasoning, it is no longer the outline of the standard.

💡 Key points. A steering indicator has a circuit: who reads it, where the data comes from, who analyzes, what the threshold triggers, who checks. A nonconformity gets corrected; only corrective action on its cause improves the system. PDCA structures a turn of the loop, it is not the outline of the standard.

▼ Worked example: the circuit of one indicator

Wiring an indicator means writing its circuit in five headings:

Circuit item	What to fill in
Who takes the reading, how often	The role, never a person's name, and the reading rhythm
Where the data comes from	The precise source: tool, register, manual reading
Who analyzes the threshold crossing	The role that qualifies the alert before any escalation
What the threshold triggers	The action planned in advance, with its deadline
Who checks the effect	The role that confirms the return below the threshold, and on what evidence

The circuit of one of the group's indicators; the others are wired the same way.

Critical vulnerabilities unpatched beyond 14 days, target zero. Read by each subsidiary's operations teams, every week; a monthly reading would let whole overruns slip through. Data: the patch management tool and the exceptions register. The subsidiary CISO qualifies every overrun, and escalation to the Group CISO is immediate, since the target is zero. Action: the fix within the deadline, or a validated formal exception. Verification: the subsidiary CISO, on the next reading.

▼ Worked example: audit findings under watch, and the holes in the net

The session 4 audit report set findings per subsidiary:

- Santé: local passwords without MFA, and the identical local administration account across the estate.
- Logistique: interconnected IT and OT networks, and the administration account shared with the maintenance provider.
- Éducation: shared administration accounts.
- Territoires: logs kept locally.

The question of continual improvement: who watches that these findings close, and with what figure? Each finding is linked to the group indicator that tracks its closure. Those no indicator watches are holes in the net.

The account-related findings, at Santé, Éducation and Logistique, are tracked by the MFA KPI on privileged accounts and by the quarterly privilege review. The local logs at Territoires are covered by the directive on collection to the SOC; a collection-rate indicator follows from it.

The hole in the net is the interconnection of the IT and OT networks at Logistique, the office network and the industrial control network. The segmentation directive has existed since session 1. The finding has been documented since session 4. No indicator measures the progress of the segmentation. The missing indicator holds

in one line: the share of flows between the IT and OT zones that pass through validated filtering points, or the progress of the segmentation plan in milestones reached, tracked by the subsidiary CISO and presented to the committee once a year. The afternoon's deliverable D9 fills this hole.